GRC WORKFLOW

Governance • Risk • Compliance

Purpose
A practical, end-to-end workflow for managing policies, risks, controls, compliance evidence, issues, and continuous improvement.

Designed for beginner learning, interview preparation, and as a starting point for an organisation’s GRC process.

Prepared by Dev Trivedi

Version 1.0 | October 2026

1. What is GRC?

Governance sets direction, accountability, policies, and oversight. **Risk Management** identifies and treats threats to business objectives. **Compliance** checks that applicable laws, regulations, contracts, and internal requirements are met.

A GRC workflow connects these activities so the organisation can show what it needs to protect, which risks matter, which controls are in place, whether they work, and what must be improved.

2. End-to-end workflow

STEP	ACTIVITY	WHAT HAPPENS
01	**Define scope & context**	Identify business units, systems, data, locations, objectives, stakeholders, and applicable obligations.
02	**Identify obligations**	List relevant laws, regulations, contracts, standards, and internal policies. Assign an owner and evidence requirement to each.
03	**Assess risk**	Identify assets and processes; record threats, vulnerabilities, existing controls, likelihood, impact, and inherent/residual risk.
04	**Select & map controls**	Choose controls to address risks and obligations. Map each control to a framework or requirement where useful.
05	**Implement controls**	Assign a control owner, define procedures, configure safeguards, train staff, and retain evidence.
06	**Test & monitor**	Test design and operating effectiveness; monitor metrics, exceptions, incidents, and overdue actions.
07	**Remediate & accept**	Create corrective actions for gaps, assign owners and due dates, validate fixes, or obtain documented risk acceptance.
08	**Report & improve**	Report risk posture and compliance status to management; review lessons learned and update the risk register and controls.

Workflow loop: Scope → Obligations → Risk assessment → Controls → Implementation → Testing → Remediation/acceptance → Reporting → Review.

3. Roles & responsibilities

ROLE	KEY RESPONSIBILITY
Executive / risk committee	Set risk appetite, approve major decisions, review significant risks and exceptions.
GRC / compliance lead	Maintain the GRC process, obligation register, risk register, control mapping, evidence calendar, and reporting.
Risk owner	Evaluate business impact, choose a treatment plan, and keep risk information current.
Control owner	Operate the control, retain evidence, report failures, and complete remediation actions.
IT / security team	Implement technical safeguards, provide logs/configuration evidence, and support technical testing.
Internal audit / independent tester	Independently evaluate design and effectiveness; report findings without owning the control.
Legal / HR / procurement / business	Provide domain-specific obligations, contract terms, training records, and process evidence.

4. Risk assessment method

Use a consistent scoring method approved by the organisation. A simple beginner model is a 1–5 scale for likelihood and impact.

SCORE	LIKELIHOOD EXAMPLE	IMPACT EXAMPLE
1 — Very low	Rare; not expected in normal conditions.	Negligible disruption or loss.
2 — Low	Unlikely but possible.	Small, contained impact.
3 — Medium	Could occur sometimes.	Noticeable service, financial, or compliance impact.
4 — High	Likely to occur.	Major disruption, material loss, or reportable issue.
5 — Very high	Expected frequently or imminent.	Severe business, legal, safety, or reputational impact.

Example calculation: Risk score = Likelihood × Impact (range 1–25). Example thresholds for learning: 1–4 Low, 5–9 Moderate, 10–16 High, 17–25 Critical. These thresholds are illustrative only; each organisation should approve its own matrix.

Risk treatment options

- **Mitigate:** add or improve controls to reduce likelihood or impact.
- **Transfer/share:** use contractual arrangements or insurance where appropriate; accountability may still remain.
- **Avoid:** stop or change the activity creating the risk.
- **Accept:** document the rationale, approver, residual risk, and review/expiry date.

5. Compliance & control evidence

For each obligation or control, maintain a traceable record. Evidence should be relevant, dated, attributable to an owner, protected from unauthorised change, and retained according to policy.

FIELD	EXAMPLE / EXPECTATION
Requirement	What rule, policy, contract, or control must be met.
Control ID & description	Unique identifier and plain-language statement of what the control does.
Owner & frequency	Named role and schedule: continuous, daily, monthly, quarterly, or annual.
Evidence	Approved policy, access review, system configuration, training report, ticket, log, or test result.
Test result	Pass, partial pass, fail, or not tested, with scope and sample details.
Finding / action	Gap, severity, action owner, due date, and validation evidence.

6. Issue & remediation lifecycle

- **Log:** create an issue record with source, affected asset/control, description, date, and evidence.
- **Rate:** assign severity based on impact, exposure, likelihood, and applicable reporting obligations.
- **Assign:** name an accountable owner, action plan, target date, and interim safeguards.
- **Track:** monitor progress and escalate overdue or high-risk issues.
- **Validate:** independently confirm the fix works and collect closure evidence.
- **Close or accept:** close only after validation, or record formal risk acceptance with an approver and expiry/review date.

> **Important:** A policy or control existing on paper does not prove it is operating effectively. GRC requires evidence and periodic testing.

7. Practical GRC registers

A small team can begin with controlled spreadsheets or a GRC platform. Restrict access and keep version history.

REGISTER	MINIMUM FIELDS	REVIEW
Obligation register	ID, requirement, source, applicability, owner, evidence, due date, status.	Quarterly and on change
Risk register	Risk ID, scenario, asset/process, likelihood, impact, score, controls, treatment, owner, due date.	Monthly/quarterly
Control register	Control ID, objective, description, owner, frequency, mapped requirements, evidence location, test result.	Quarterly
Issue/action log	Issue ID, source, severity, owner, corrective action, due date, status, validation, closure approval.	Weekly/monthly
Policy register	Policy name, owner, approver, version, effective date, next review, audience, acknowledgement.	Annual or on change
Evidence index	Evidence ID, control/requirement, period, source, owner, storage path, access class, retention date.	Each cycle

8. Suggested operating cadence

CADENCE	ACTIVITY
Weekly	Review overdue remediation actions, urgent findings, and incidents that may affect compliance or risk.
Monthly	Review top risks, control failures, exceptions, risk indicators, and action-plan progress.
Quarterly	Refresh risk assessments, sample control evidence, review obligation changes, and report to leadership.
Annually / on major change	Review policies, scope, risk appetite, business continuity assumptions, third-party risk, and GRC programme effectiveness.

9. Sample workflow example

Scenario: A quarterly access review for a business application is overdue.

- **Identify:** The control calendar flags the access review as overdue.
- **Assess:** The control owner and GRC lead determine whether inappropriate access could remain active and rate the exposure.
- **Contain:** If needed, review privileged or high-risk accounts immediately while the full review is completed.
- **Evidence:** Export the user list, manager approvals, changes/removals, ticket references, and completion date.
- **Test:** A reviewer checks the evidence and a sample of changes to confirm the review operated as intended.
- **Remediate:** Log any missing approvals or stale access, assign owners and deadlines, and validate removals.
- **Report:** Record the outcome, residual risk, overdue reason, and any accepted exception.

10. GRC dashboard metrics

- Percentage of key controls tested on schedule.
- Percentage of controls passing effectiveness tests.
- Number of high/critical risks without an approved treatment plan.
- Number and age of overdue remediation actions.
- Compliance obligations with current evidence versus total applicable obligations.
- Policy reviews and required training completed on time.
- Third-party assessments overdue or with unresolved high-risk findings.

11. Implementation checklist

- Define scope, objectives, risk appetite, and accountable stakeholders.
- Create obligation, risk, control, issue, policy, and evidence registers.
- Agree on risk scoring, escalation thresholds, and risk acceptance authority.
- Map key controls to relevant requirements and assign owners/frequencies.
- Set an evidence storage method, access permissions, naming rules, and retention periods.
- Schedule control tests and recurring risk/compliance reviews.
- Create an escalation and remediation process with due dates and validation.
- Deliver a concise monthly or quarterly report to decision-makers.

12. Frameworks and important caveat

Depending on the organisation and sector, GRC programmes may map controls to frameworks such as ISO/IEC 27001, NIST Cybersecurity Framework, NIST SP 800-53, SOC 2 Trust Services Criteria, or applicable privacy and sector regulations. Choose only requirements that actually apply and verify the current version and legal obligations with qualified stakeholders.

This document is a general educational workflow, not legal advice, a certification guarantee, or a substitute for a tailored risk assessment. Adjust ownership, scoring, evidence, testing, and reporting to the organisation’s size, industry, jurisdiction, and contractual commitments.